

LocalMarket POS & Pawn Manager

Security & Test-Environment Pack

Purpose: A repeatable, isolated test plan for staff/PIN/security flows before wider app testing. All identities and credentials below are synthetic test values.

1. Recommended Test Shop

Field	Synthetic test value
Shop name	LocalMarket Security Test Shop
Shop code	TEST-SEC-01
Owner	Test Owner
Owner email	test.owner@example.invalid
Cashier	Test Cashier
Cashier code	TEST-CASH-01
Test PIN	246810
Timezone	Africa/Johannesburg

Important: These values belong only in a test environment. Do not create this test employee in the live shop merely to recover a forgotten production PIN. Use the authorized PIN-reset workflow for real staff.

2. Security API Calls to Test

Method	Endpoint	Test condition	Expected result
GET	/api/health	No auth	200; JSON; status=ok
POST	/api/staff/provision	No auth	401; must never provision
POST	/api/verify-pin	No auth	401; must never verify
POST	/api/auth/login-with-pin	Invalid PIN length	400; rejects non-6-digit PIN
POST	/api/auth/login-with-pin	Valid synthetic PIN	Successful login in isolated test data
POST	/api/staff/provision	Valid authenticated Owner	Creates only permitted role

3. Safe cURL Examples

Health check

```
curl -i https://local-market-nine.vercel.app/api/health
```

Unauthenticated provisioning must fail

```
curl -i -X POST https://local-market-nine.vercel.app/api/staff/provision -H "Content-Type: application/json" -d '{"shopId":"TEST-SEC-01","fullName":"Test Cashier","cashierCode":"TEST-CASH-01","pin":"246810","role":"cashier"}'
```

Expected: HTTP 401 and JSON error. No user should be created.

PIN format validation

```
curl -i -X POST https://local-market-nine.vercel.app/api/auth/login-with-pin -H "Content-Type: application/json" -d '{"cashierCode":"TEST-CASH-01","pin":"123"}'
```

Expected: HTTP 400 because the PIN is not six numeric digits.

4. PIN Security Checks

- PINs must not be returned in staff-list/profile API responses.
- PINs must not be stored as plaintext when a hashed PIN is available.
- Wrong PIN must not create a session.
- Inactive staff must not authenticate.
- Unauthenticated provisioning must return JSON 401 and create nothing.
- Managers must not create/promote another Manager, Owner, or Admin.
- PIN resets should be audited without storing the new PIN in the audit log.
- The Supabase service-role credential must remain server-side and must never use a VITE_ prefix.
- Test credentials must never be reused for a real shop.

5. Current LocalMarket Security Architecture

The current repository uses a server-side Supabase Admin client for privileged staff operations. The service-role key is required for that client and must not fall back to the public anon key. Caller authentication is performed separately using the caller's bearer token before privileged staff operations.

Relevant routes include `/api/health`, `/api/staff/provision`, `/api/verify-pin`, and `/api/auth/login-with-pin`. The release verification suite also checks unauthenticated rejection, PIN input validation, PBKDF2 PIN hashing/verification, and serverless startup behavior.

6. Test Sequence

1. Use an isolated test database/project, or a clearly isolated test-shop dataset.
2. Create the synthetic shop and synthetic Owner/Test Cashier only there.
3. Confirm `/api/health` returns JSON and `mode=serverless` on Vercel.
4. Confirm unauthenticated `/api/staff/provision` returns 401.
5. Confirm invalid PIN length returns 400.
6. Confirm the synthetic Cashier can authenticate with the known test PIN.
7. Switch account and verify the Cashier session/role is actually applied.
8. Test inactive staff, wrong PIN, and role-boundary cases.
9. Review staff audit entries.
10. Only after these checks pass, repeat the flow with real shop accounts.

7. Forgotten Real PIN Recovery

Do not bypass the PIN check or add a hidden master PIN. Use the authorized staff PIN-reset workflow. If the Owner PIN itself is forgotten, recovery should be an explicit account-recovery procedure rather than a backdoor embedded in the POS.

Honest recommendation: A disposable security-test dataset is the right approach. A known synthetic PIN is useful for testing, but it must never become a production backdoor.